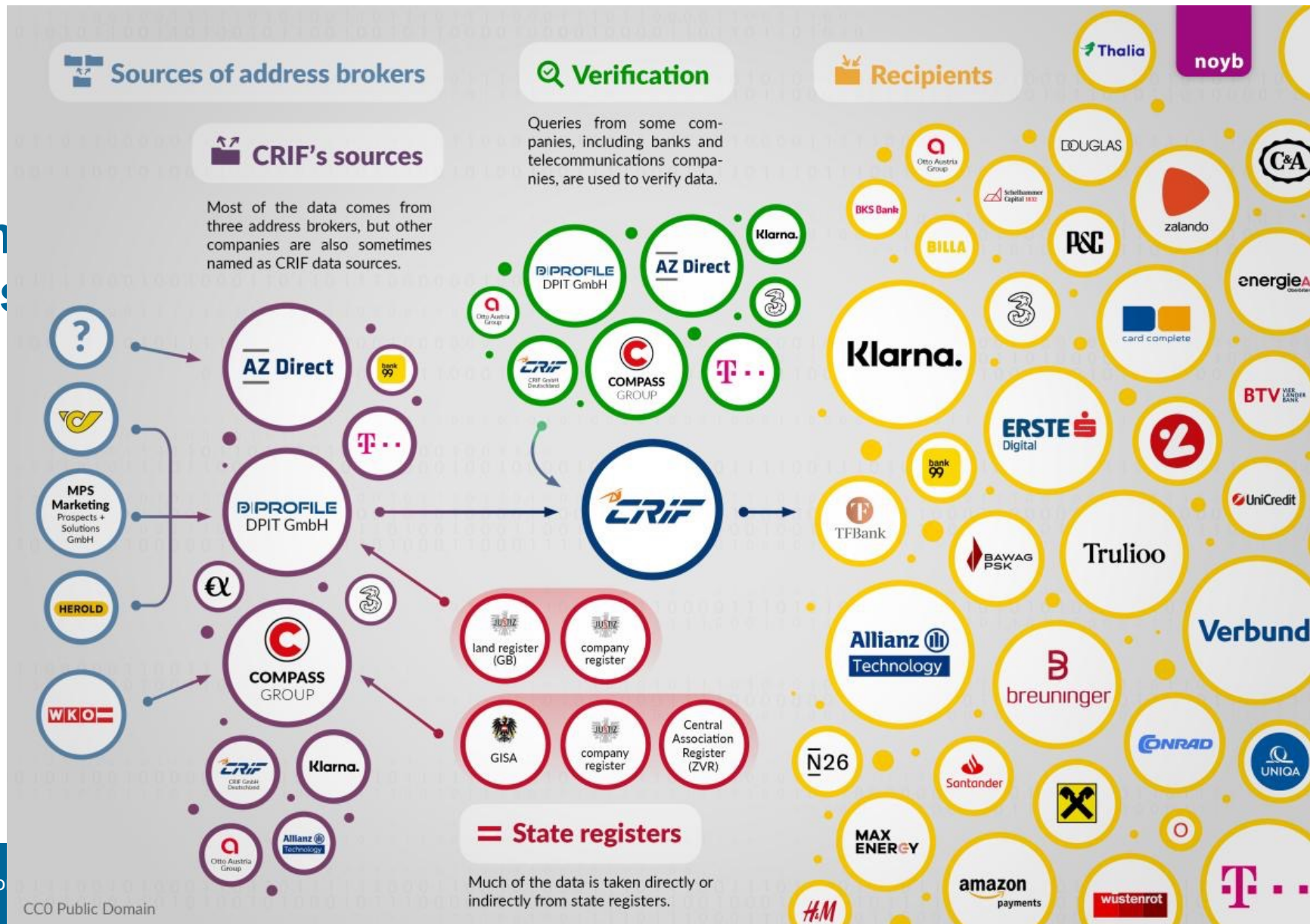


Warum Datens





TECHNISCHE
UNIVERSITÄT
WIEN

Daten und Informatikrecht

Datenschutz

Geschichte – Ärzte Eid

■ 400 BC: Hippokratischer Eid

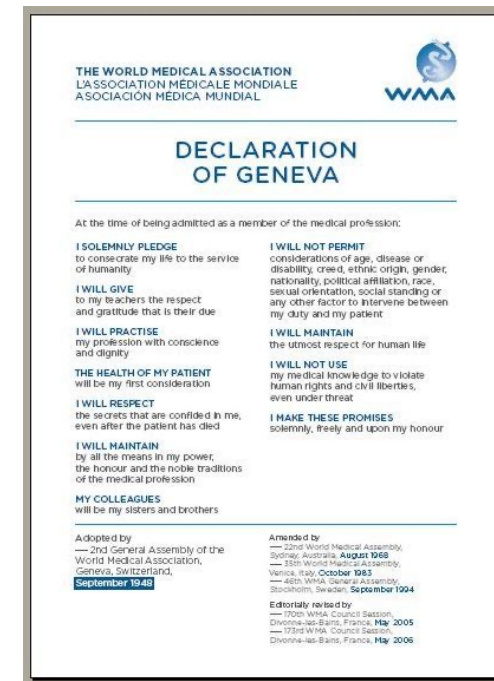
Ich schwöre, [...] Was immer ich über das Leben von Menschen innerhalb, aber auch ausserhalb der Behandlung sehe oder vernehme, was niemals nach draussen ausgeplaudert werden darf, werde ich verschweigen, wann immer ich es für geheim halte.

ΟΜΝΥΜΙ ΑΠΟΛΛΩΝΑ ΙΗΤΡΟΝ ΚΑΙ ΑΣΚΛΗΠΙΟΝ ΚΑΙ ΥΓΙΕΙΑΝ ΚΑΙ ΠΑΝΑΚΕΙΑΝ ΚΑΙ ΘΕΟΥΣ ΠΑΝΤΑΣ ΤΕ ΚΑΙ ΠΑΣΑΣ ΙΣΤΟΡΑΣ ΠΟΙΕΥΜΕΝΟΣ ΕΠΙΤΕΛΕΑ ΠΟΙΗΣΕΙΝ ΚΑΤΑ ΔΥΝΑΜΙΝ ΚΑΙ ΚΡΙΣΙΝ ΕΜΗΝ ΟΡΚΟΝ ΤΟΝΔΕ ΚΑΙ ΕΥΤΤΡΑΦΗΝ ΤΗΝΔΕ ΗΓΗΣΑΣΘΑΙ ΤΕ ΤΟΝ ΔΙΔΑΣΚΑΝΤΑ ΜΕ ΤΗΝ ΤΕΧΝΗΝ ΤΑΥΤΗΝ ΙΣΑ ΓΕΝΕΤΗΣΙΝ ΕΜΟΙΣΙΝ ΚΑΙ ΒΙΟΥ ΚΟΙΝΩΣΑΣΘΑΙ ΚΑΙ ΧΡΕΩΝ ΧΡΗΖΟΝΤΙ ΜΕΤΑΔΟΣΙΝ ΠΟΙΗΣΑΣΘΑΙ ΚΑΙ ΓΕΝΟΣ ΤΟ ΕΞ ΑΥΤΟΥ ΑΔΕΛΦΕΥΣ ΙΣΟΝ ΕΠΙΚΡΙΝΕΙΝ ΑΡΡΕΣΙ ΚΑΙ ΔΙΔΑΣΚΕΙΝ ΤΗΝ ΤΕΧΝΗΝ ΤΑΥΤΗΝ ΗΝ ΧΡΗΖΩΣΙ ΜΑΝΘΑΝΕΙΝ ΑΝΕΓ' ΜΙΣΘΟΥ ΚΑΙ ΕΥΤΤΡΑΦΗΣ ΠΑΡΑΓΓΕΛΙΑΣ ΤΕ ΚΑΙ ΑΚΡΟΗΣΙΟΣ ΚΑΙ ΤΗΣ ΛΟΙΠΗΣ ΑΠΑΣΗΣ ΜΑΘΗΣΙΟΣ ΜΕΤΑΔΟΣΙΝ ΠΟΙΗΣΑΣΘΑΙ ΥΙΟΙΣΙ ΤΕ ΕΜΟΙΣΙ ΚΑΙ ΤΟΙΣΙ ΤΟΥ ΕΜΕ ΔΙΔΑΣΚΑΝΤΟΣ ΚΑΙ ΜΑΘΗΤΑΙΣΙ ΣΥΓΓΕΓΡΑΜΜΕΝΟΙΣ ΤΕ ΚΑΙ ΩΡΚΙΣΜΕΝΟΙΣ ΝΟΜΩ ΙΗΤΡΙΚΩ ΑΛΛΩ ΔΕ ΟΥΔΕΝΙ ΔΙΑΙΤΗΜΑΣΙ ΤΕ ΧΡΗΣΟΜΑΙ ΕΠΙ ΩΦΕΛΕΙΑΙ ΚΑΜΝΟΝΤΩΝ ΚΑΤΑ ΔΥΝΑΜΙΝ ΚΑΙ ΚΡΙΣΙΝ ΕΜΗΝ ΕΠΙ ΔΗΛΗΣΕΙ ΔΕ ΚΑΙ ΑΔΙΚΗΝ ΕΙΡΞΕΙΝ ΟΥ ΔΟΣΩ ΔΕ ΟΥΔΕ ΦΑΡΜΑΚΟΝ ΟΥΔΕΝΙ ΑΙΤΗΘΕΙΣ ΘΑΝΑΣΙΜΟΝ ΟΥΔΕ ΥΦΗΓΗΣΟΜΑΙ ΕΥΜΒΟΥΛΗΝ ΤΟΙΗΝΔΕ ΟΜΟΙΩΣ ΔΕ ΟΥΔΕ ΓΥΝΑΙΚΙ ΠΙΣΣΩΝ ΦΘΟΡΙΟΝ ΔΟΣΩ ΑΓΝΩΣ ΔΕ ΚΑΙ ΟΣΙΩΣ ΔΙΑΤΗΡΗΣΩ ΒΙΟΝ ΤΟΝ ΕΜΟΝ ΚΑΙ ΤΕΧΝΗΝ ΤΗΝ ΕΜΗΝ ΟΥ ΤΕΜΕΩ ΔΕ ΟΥΔΕ ΜΗΝ ΛΙΘΙΩΝΤΑΣ ΕΚΧΟΡΗΣΩ ΔΕ ΕΡΓΑΤΗΣΙΝ ΑΝΔΡΑΣΙΝ ΠΙΡΗΙΟΣ ΤΗΣΔΕ ΕΣ ΟΙΚΙΑΣ ΔΕ ΟΚΟΣΑΣ ΑΝ ΕΣΩ ΕΞΕΛΕΥΣΟΜΑΙ ΕΠΙ ΩΦΕΛΕΙΑΙ ΚΑΜΝΟΝΤΩΝ ΕΚΤΟΣ ΕΩΝ ΠΑΣΗΣ ΑΔΙΚΗΣ ΕΚΟΥΣΙΗΣ ΚΑΙ ΦΘΟΡΙΣ ΤΗΣ ΤΕ ΑΛΛΗΣ ΚΑΙ ΑΦΡΟΔΙΣΙΩΝ ΕΡΩΝ ΕΠΙ ΤΕ ΓΥΝΑΙΚΕΙΩΝ ΣΩΜΑΤΩΝ ΚΑΙ ΑΝΔΡΕΙΩΝ ΕΛΕΥΘΕΡΩΝ ΤΕ ΚΑΙ ΔΟΥΛΩΝ ΑΔΑΝ ΕΝ ΘΕΡΑΠΕΙΑΙ Η ΙΔΩ Η ΑΚΟΥΣΩ Η ΚΑΙ ΑΝΕΓ' ΘΕΡΑΠΗΗΣ ΚΑΤΑ ΒΙΟΝ ΑΝΘΡΩΠΩΝ Α ΜΗ ΧΡΗ ΠΟΤΕ ΕΚΑΛΛΕΕΣΘΑΙ ΕΞΩ ΣΙΓΗΣΟΜΑΙ ΑΡΡΗΤΑ ΗΓΕΥΜΕΝΟΣ ΕΙΝΑΙ ΤΑ ΤΟΙΑΥΤΑ ΟΡΚΟΝ ΜΕΝ ΟΥΝ ΜΟΙ ΤΟΝΔΕ ΕΠΙΤΕΛΕΑ ΠΟΙΕΟΝΤΙ ΚΑΙ ΜΗ ΞΥΓΧΕΟΝΤΙ ΕΙΗ ΕΠΑΥΡΑΣΘΑΙ ΚΑΙ ΒΙΟΥ ΚΑΙ ΤΕΧΝΗΣ ΔΟΞΑΖΟΜΕΝΩ ΠΑΡΑ ΠΑΣΙΝ ΑΝΘΡΩΠΟΙΣ ΕΣ ΤΟΝ ΔΕΙ ΧΡΟΝΟΝ ΠΑΡΑΒΑΙΝΟΝΤΙ ΔΕ ΚΑΙ ΕΠΙΟΡΚΟΥΝΤΙ ΤΑΝΑΤΙΑ ΤΟΓΤΕΩΝ

Geschichte – Ärzte Eid

1948: Genfer Gelöbnis

Als Mitglied der ärztlichen Profession gelobe ich feierlich, mein Leben in den Dienst der Menschlichkeit zu stellen.
[...] Ich werde die mir anvertrauten Geheimnisse auch über den Tod der Patientin oder des Patienten hinaus wahren.



Geschichte

1215 AD: Beichtgeheimnis

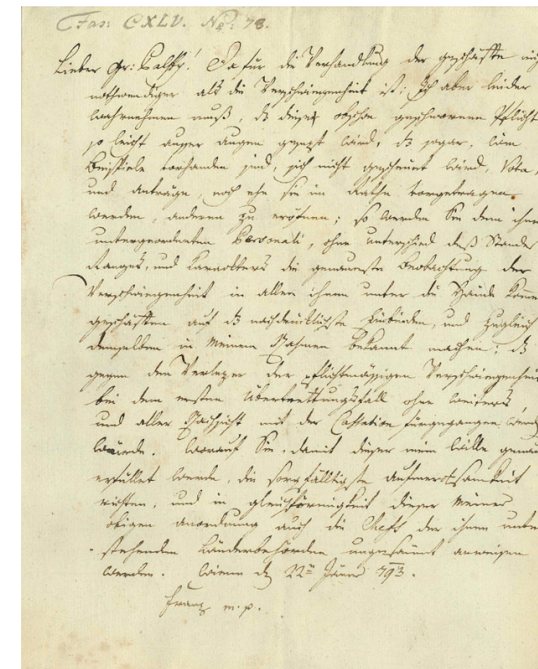
Viertes Laterankonzil

Das Beichtgeheimnis verpflichtet Geistliche zu absoluter Verschwiegenheit über alles, was ihnen in der Beichte anvertraut wird. Nicht einmal die Beichtenden selbst können ihre Beichtväter von der Schweigepflicht entbinden. Geistlichen, die das Beichtgeheimnis verletzen, droht der Ausschluss aus der Kirche.



Geschichte – Amtsgeheimnis

- Art 20 B-VG (3) 1925
- Informationsfreiheitsgesetz 01.09.2025
 - Proaktive Veröffentlichungspflicht im Informationsregister (www.data.gv.at)
 - Grundrecht auf Zugang zu Informationen – Informationen auf Antrag



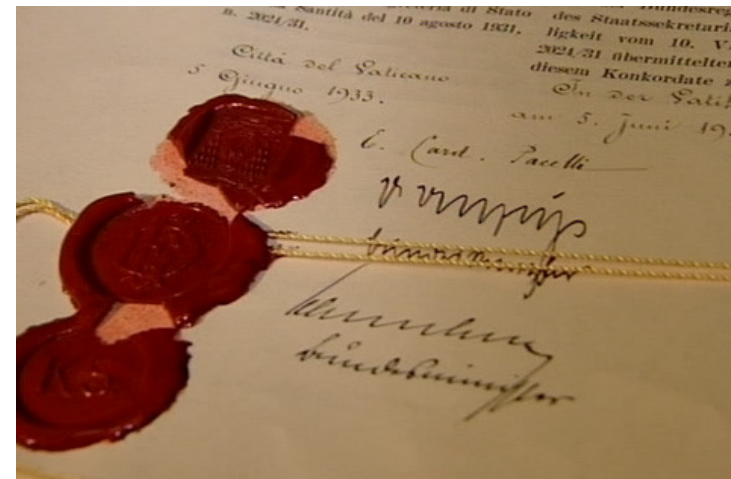


Exkurs: Informationsfreiheitsgesetz

- Informationen „von allgemeinem Interesse" müssen vom Bund, Länder, Gemeinden (> 5.000), ... proaktiv veröffentlicht werden.
- Beispiele: GE, Studien, Gutachten, Umfragen, Verträge, ...
- Ausnahme: Geheimhaltungsgrund (nationale Sicherheit, Datenschutz)
- Frist: Vier Wochen (bzw. 8 Wochen)

Geschichte - Beichtgeheimnis

- Art. 15 Staatsgrundgesetz
(Dezemberverfassung 21.12.1867)
- Konkordat 1933
- OGH 1978 „Die allgemeine
Zeugenpflicht ist [...] aufgehoben und
die Vernehmung unzulässig, als der
Gegenstand der Abhörung das
Geheimnis der Beichte betrifft.“



Geschichte – Briefgeheimnis

- 1917: Allgemeine Preußische Postordnung. Zuwiderhandeln, drohten die Dienstentlassung und die strafrechtliche Verfolgung als „Meineidiger“.
- 1974 Allgemeine Preußische Landrecht
- 1919 Deutsches Grundrecht



Geschichte – Briefgeheimnis

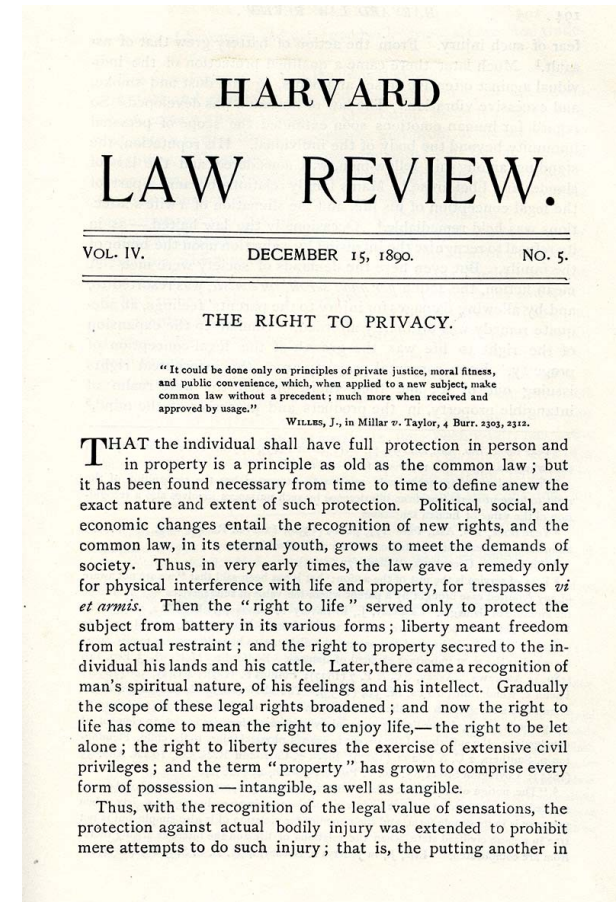
In Österreich auf Verfassungsrang

- Art. 10 StGG
- Art. 8 EMRK
(Europäische Menschenrechtskonvention)
- § 118 StGB „Freiheitsstrafe bis zu drei Monaten oder mit Geldstrafe bis zu 180 Tagessätzen“

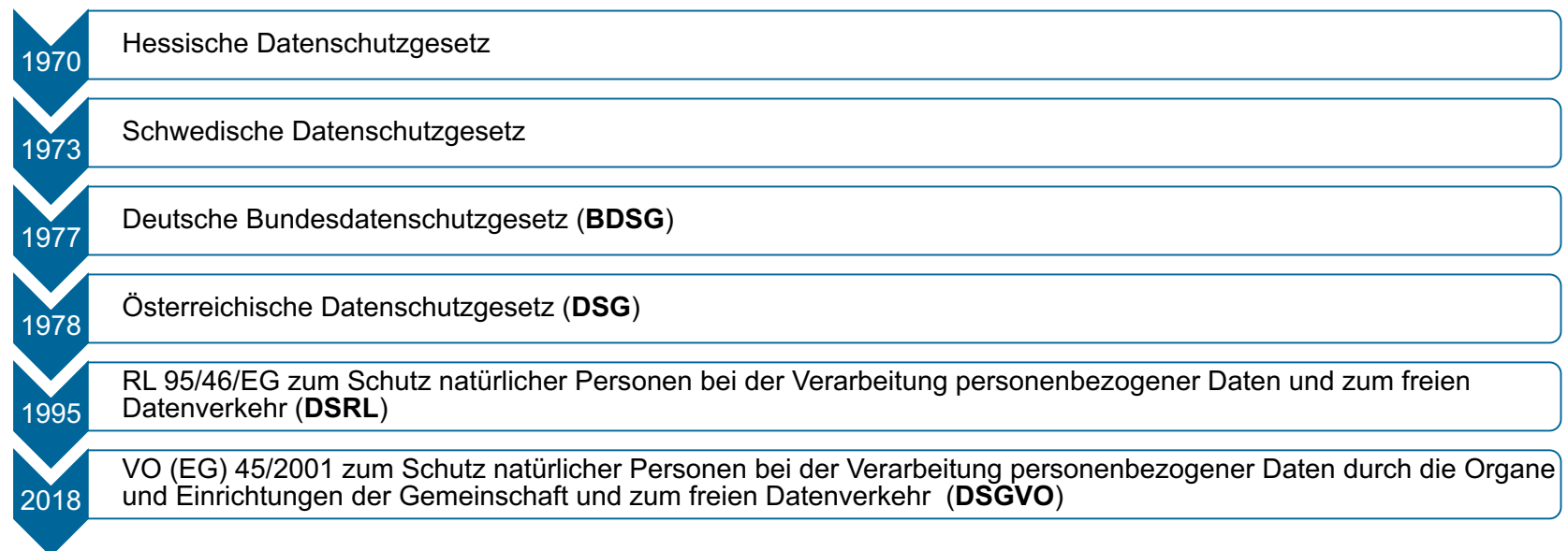


Geschichte – US

- 1890 Artikel im Harvard Law Review
- Louis D. Brandeis, Samuel D. Warren
- Konzept moderner Datenschutz
- Plädieren für den Schutz der Privatsphäre.



Historie



DIREGGER, HANDBUCH DATENSCHUTZRECHT



TECHNISCHE
UNIVERSITÄT
WIEN

Was ist Datenschutz?

Datenschutz

- Recht auf Schutz **personenbezogener Daten**. [Art. 1 \(2\) DSGVO](#)
- ganz oder teilweise [...] sowie für die nichtautomatisierte **Verarbeitung** personenbezogener Daten. [Art. 2 \(1\) DSGVO](#)
- „personenbezogene Daten“ alle Informationen, die sich auf eine [...] **identifizierbare** natürliche Person beziehen [...] die **direkt oder indirekt**, insbesondere mittels **Zuordnung** zu einer Kennung wie einem Namen, zu einer Kennnummer, zu Standortdaten, zu einer Online-Kennung oder zu einem oder mehreren besonderen Merkmalen, die Ausdruck der physischen, physiologischen, genetischen, psychischen, wirtschaftlichen, kulturellen oder sozialen **Identität dieser natürlichen Person** sind, identifiziert werden kann. [Art. 3 Z 1 DSGVO](#)

Datenschutz

- „Verarbeitung“ jeden mit oder ohne Hilfe automatisierter Verfahren ausgeführten Vorgang oder jede solche Vorgangsreihe im Zusammenhang mit personenbezogenen Daten wie das **Erheben**, das **Erfassen**, die **Organisation**, das **Ordnen**, die **Speicherung**, die **Anpassung** oder **Veränderung**, das **Auslesen**, das **Abfragen**, die **Verwendung**, die Offenlegung durch **Übermittlung**, Verbreitung oder eine andere Form der **Bereitstellung**, den **Abgleich** oder die **Verknüpfung**, die **Einschränkung**, das **Löschen** oder die **Vernichtung**
Art. 3 Z 2 DSGVO

Sensible Daten

- Personenbezogene Daten, aus denen die rassische und ethnische Herkunft, politische Meinungen, **religiöse** oder **weltanschauliche** Überzeugungen oder die Gewerkschaftszugehörigkeit hervorgehen, sowie die Verarbeitung von **genetischen** Daten, **biometrischen** Daten zur eindeutigen Identifizierung einer natürlichen Person, **Gesundheitsdaten** oder Daten zum Sexualleben oder der sexuellen **Orientierung** einer natürlichen Person.

Pseudonymisierung vs. Anonymisierung

Pseudonymisierung vs. Anonymisierung

Zuordnungstabelle
| Patient 392B | Heinz Schmidt |

Heinz Schmidt hat
einen Gamma-GT-
Wert von 83 U/L

Personenbezogene
Daten

Patient 392B hat
einen Gamma-GT-
Wert von 83 U/L

Pseudonymisierte
Daten

Ein Patient hat
einen Gamma-GT-
Wert von 83 U/L

Anonymisierte
Daten

Pseudonymisierung vs. Anonymisierung

Pseudonymisierung

- Daten können mit leichtem Aufwand wiederhergestellt werden.
(z.B.: Look-Up-Table, ...)
- Eventuell Vorteile bei Datenpanne
- Daten unterliegen der DSGVO
- Nicht geeignet für die Umsetzung eines Löschantrags

Anonymisierung

- Daten können nur mit erheblichem Aufwand wiederhergestellt werden.
(z.B.: K-Anonymity, ...)
- Datenpanne unbedenklich
- Daten unterliegen nicht der DSGVO
- Geeignet für die Umsetzung eines Löschantrags

Geltungsbereich

- Verarbeitung von personenbezogenen Daten
 - Personenbezogene Daten: Daten die sich auf eine natürliche Person beziehen
 - Verarbeiten: Jede Interaktion
- Verantwortliche oder Auftragsverarbeiter
 - Sitz in EU
 - Marktortprinzip
 - Waren oder Dienstleistung in EU angeboten
 - Verhalten von Personen in der EU beobachtet

Prinzipien (Art. 5 DSGVO)

Rechtmäßigkeit, Verarbeitung nach Treu und Glauben, Transparenz

- Datenverarbeitung rechtmäßig (Einwilligung oder Rechtsgrundlage)
- Betroffene Person ist in der Lage von der Datenverarbeitung zu erfahren
- Auskunftsrecht über personenbezogene Daten, Zweck der Verarbeitung, ...
- Informationen zur Verarbeitung sind leicht zugänglich und verständlich

Prinzipien (Art. 5 DSGVO)

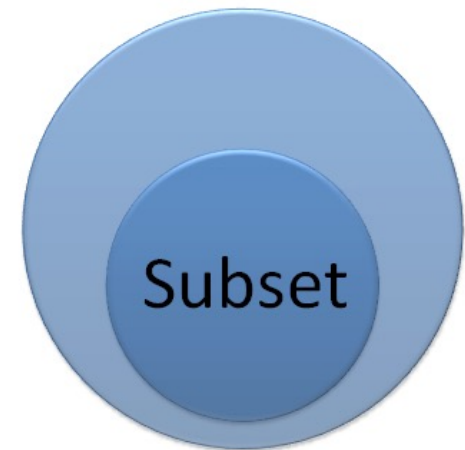
Zweckbindung

- Zweck ist festgelegt, eindeutig und legitim.
- Öffentliches Interesse: Archivzwecke, für wissenschaftliche oder historische Forschungszwecke oder für statistische Zwecke

Prinzipien (Art. 5 DSGVO)

Datenminimierung

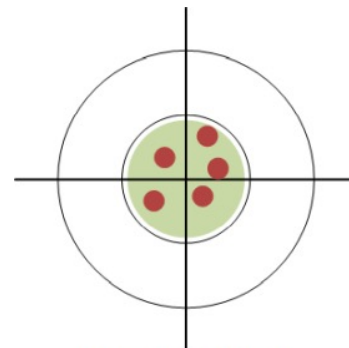
- Datenverarbeitung dem Zweck angemessen
- Datenverarbeitung auf das notwendige Maß beschränkt
- Ziel: Minimal Data Set (MDS)



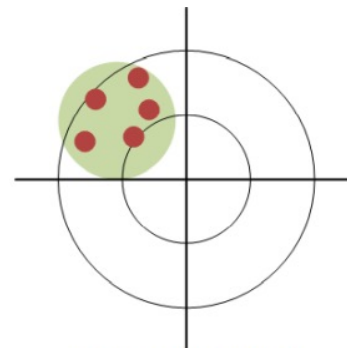
Prinzipien (Art. 5 DSGVO)

Richtigkeit

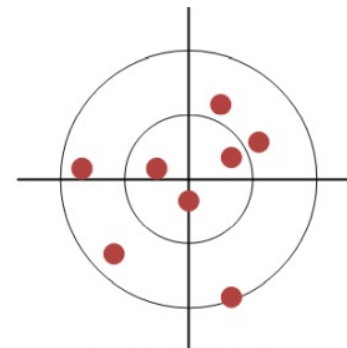
- Sachlich richtig
- Aktuell
- Recht auf Berichtigung, Löschung



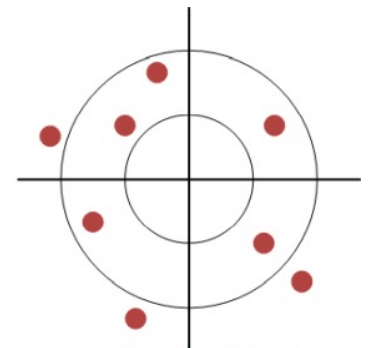
Hohe Richtigkeit
Hohe Präzision
Hohe Genauigkeit



Geringe Richtigkeit
Hohe Präzision
Geringe Genauigkeit



Hohe Richtigkeit
Geringe Präzision
Geringe Genauigkeit

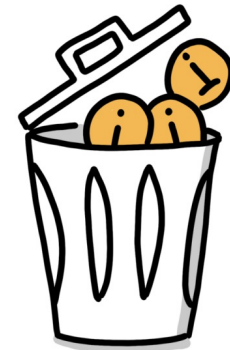


Geringe Richtigkeit
Geringe Präzision
Geringe Genauigkeit

Prinzipien (Art. 5 DSGVO)

Speicherbegrenzung

- Speicherfrist auf das unbedingt erforderliche Mindestmaß beschränkt
- Pflicht für Löschfristen und regelmäßige Überprüfungen

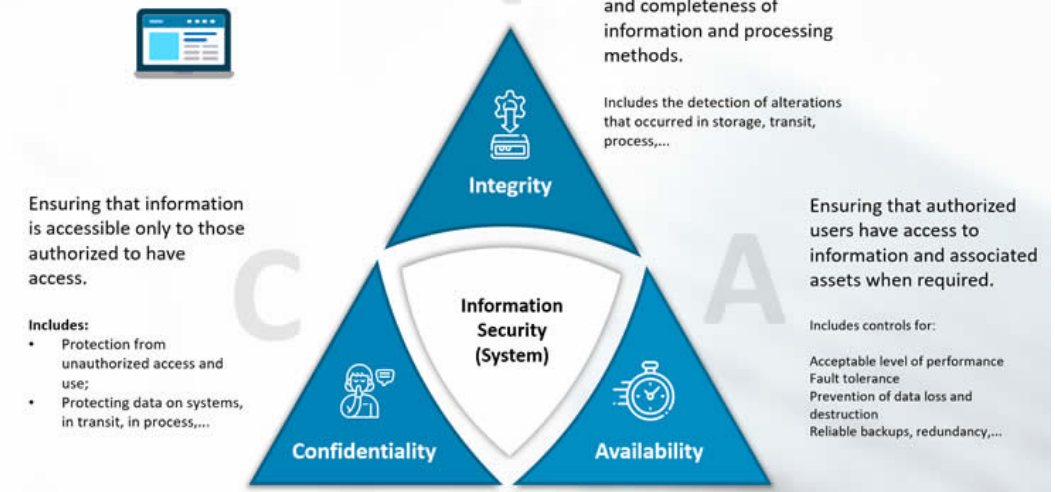


Prinzipien (Art. 5 DSGVO)

Integrität und Vertraulichkeit

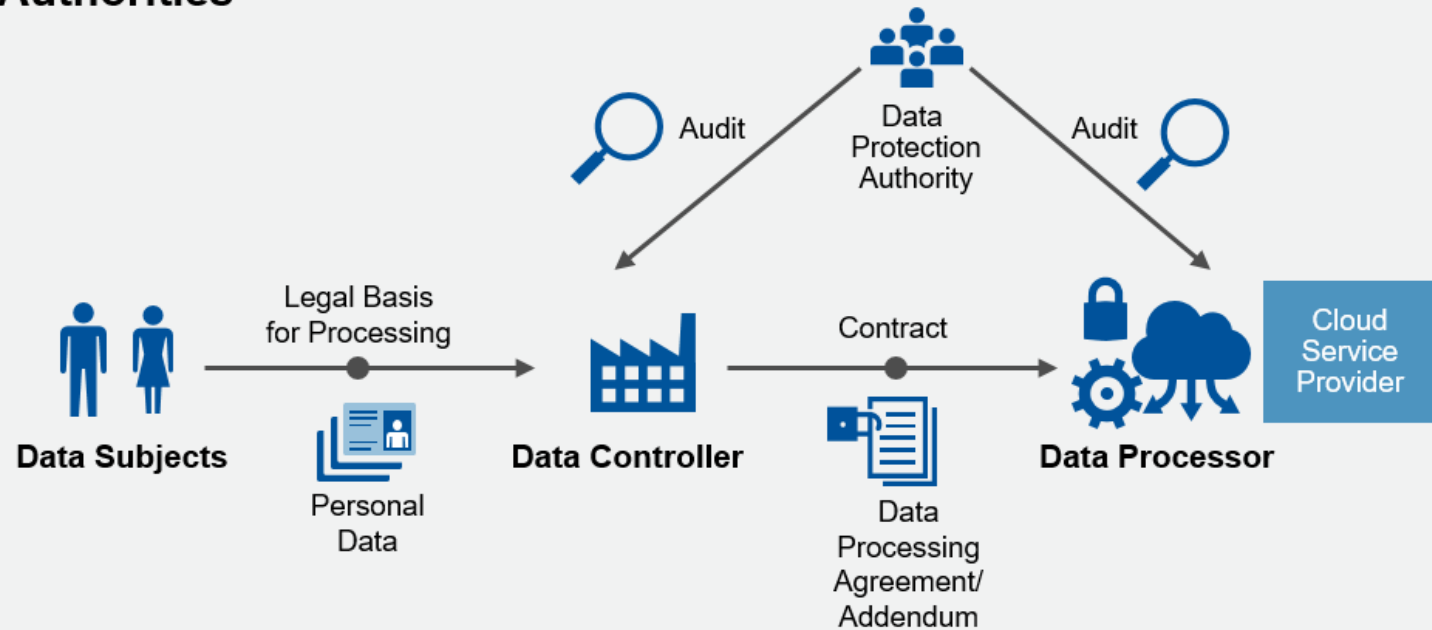
- Siehe CIA triad

CYBERSECURITY – INFOSEC CIA TRIAD



Rollen

GDPR Roles: Data Subjects, Controller, Processor and Protection Authorities



ID: 348233

© 2018 Gartner, Inc.



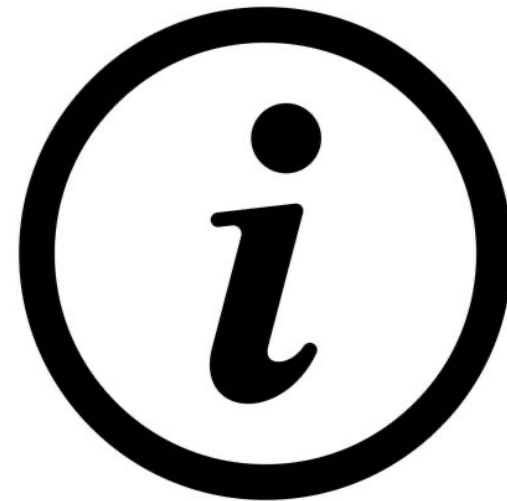
TECHNISCHE
UNIVERSITÄT
WIEN

Betroffenenrechte

Betroffenenrechte

Informationsrecht

Betroffene Person ist u.a. in Kenntnis, dass Ihre personenbezogenen Daten verarbeitet werden.



Betroffenenrechte

Auskunftsrecht

- Daten
- Verarbeitungszwecke
- Quellen und Empfänger
- Speicherfrist
- Ggf. Logik bei Entscheidungen, die auf einer automatisierten Verarbeitung beruhen.
- Ggf. Garantien für internationale Datentransfers

Betroffenenrechte

Auskunftsrecht

- Grundsätzlich schriftlich Beantwortung (strukturierten, gängigen und maschinenlesbaren Format)
- Auf Wunsch mündlich Beantwortung möglich.
- Identität muss vom Verantwortlichen sichergestellt werden.
- Ggf. Negativauskunft (“Leermeldung“) erforderlich

Betroffenenrechte

Recht auf Berichtigung

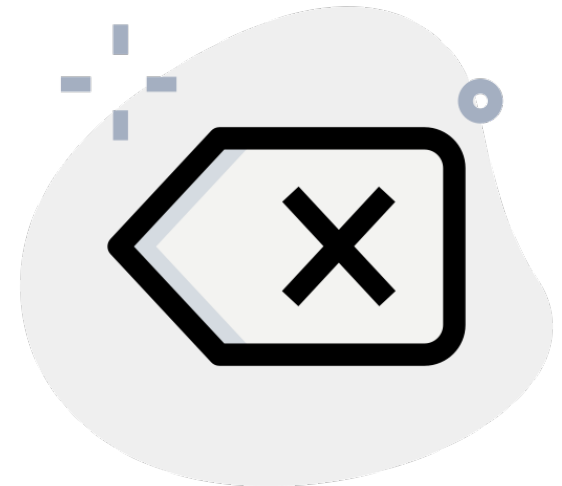
- Änderung, Vervollständigung von Daten



Betroffenenrechte

Recht auf Löschung

- Daten sind für Zweck nicht mehr notwendig
- Widerruf der Einwilligung



Betroffenenrechte

Recht auf Löschung – Ablehnungsgründe:

- Freie Meinungsäußerung und Information
- Erfüllung einer rechtlichen Verpflichtung (z.B.: Aufbewahrungspflichten)
- Öffentlichen Interesses im Bereich der öffentlichen Gesundheit
- Archivzwecke, wissenschaftliche, historische Forschungszwecke, statistische Zwecke
- Geltendmachung, Ausübung oder Verteidigung von Rechtsansprüchen

Betroffenenrechte

Recht auf Einschränkung

- Daten dürfen nur mehr gespeichert werden.



Betroffenenrechte

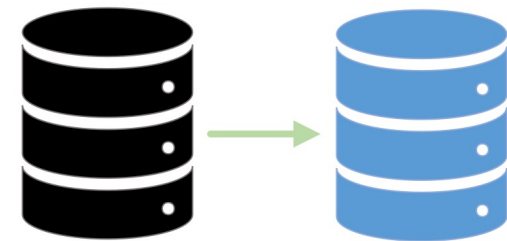
Alternative zur Löschung, das Recht auf Einschränkung z.B.

- Richtigkeit wird bestritten, Prüfung ausständig
- Widerspruch gegen die Verarbeitung eingelegt, Prüfung ausständig
- Daten sind für definierten Zweck nicht mehr notwendig, jedoch zur Geltendmachung, Ausübung oder Verteidigung von Rechtsansprüchen.

Betroffenenrechte

Recht auf Datenübertragbarkeit

- Betroffene Person erhält die Daten in einem strukturierten, gängigen und maschinenlesbaren Format.
- Betroffene Person darf Daten einem anderen Verantwortlichen übermitteln



Betroffenenrechte

Recht auf Datenübertragbarkeit

- System muss nicht angepasst werden, sofern die Daten in einem strukturierten, gängigen und maschinenlesbaren Format übermittelt werden.
- Alle personenbezogenen Daten betroffen (auch Nutzungsdaten)
- Datensicherungsmaßnahmen bei der Übertragung erforderlich.
- Rechte von Dritten sind zu beachten. (Urheberrecht, Briefgeheimnis, ...)
- Geschäftsgeheimnisse, erzeugte Daten (Profil, ...) müssen nicht übertragen werden.

Betroffenenrechte

Widerspruchsrecht

- Daten dürfen nicht weiterverarbeitet werden.



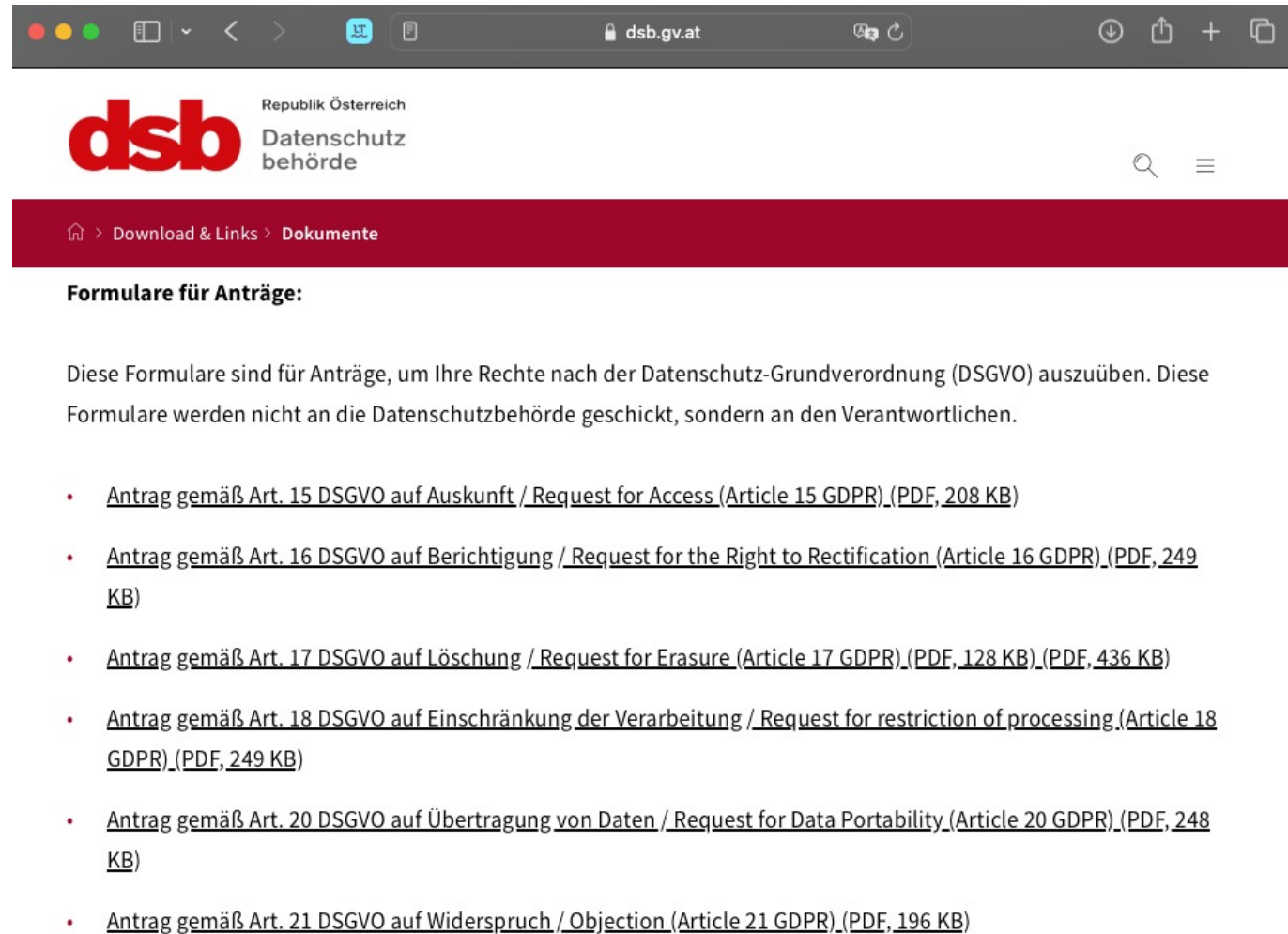
Betroffenenrechte

Widerspruchsrecht – Ablehnungsgründe

- Rechtsgrundlage
- Verarbeitung erfolgt zu wissenschaftlichen, historischen oder statistischen Zwecken und ist zur Erfüllung einer Aufgabe im öffentlichen Interesse
- Verarbeitung dient der Geltendmachung, Ausübung oder Verteidigung von Rechtsansprüchen.

Betroffenenrechte

- **Frist:** 1 Monat (ggF. 3 Monate, bei hoher Komplexität oder vielen Anfragen)
- **Kostenlos**, ausgenommen offenkundig unbegründeten / exzessiven Anträgen
- **Eskalation:** Binnen eines Jahres bei der DSb
- **Geldstrafen:** 20 Mio. EUR oder 4% des weltweiten Jahresumsatzes

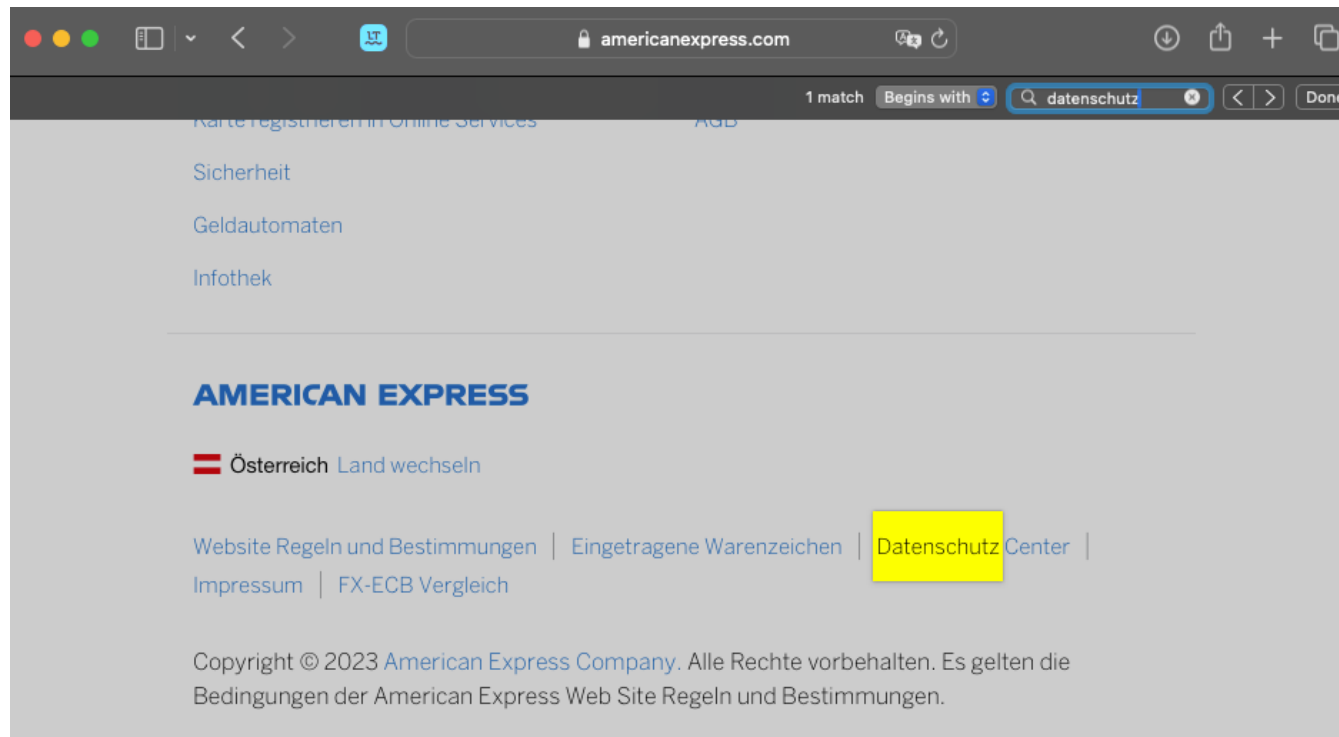


The screenshot shows a web browser window with the address bar displaying 'dsb.gv.at'. The website header features the 'dsb' logo and the text 'Republik Österreich Datenschutzbehörde'. A red navigation bar contains the breadcrumb 'Download & Links > Dokumente'. Below this, the section 'Formulare für Anträge:' is followed by a paragraph explaining that these forms are for exercising rights under the DSGVO and are sent to the responsible party, not the authority. A list of six links follows, each for a specific article of the DSGVO and its corresponding PDF form.

Formulare für Anträge:

Diese Formulare sind für Anträge, um Ihre Rechte nach der Datenschutz-Grundverordnung (DSGVO) auszuüben. Diese Formulare werden nicht an die Datenschutzbehörde geschickt, sondern an den Verantwortlichen.

- [Antrag gemäß Art. 15 DSGVO auf Auskunft / Request for Access \(Article 15 GDPR\) \(PDF, 208 KB\)](#)
- [Antrag gemäß Art. 16 DSGVO auf Berichtigung / Request for the Right to Rectification \(Article 16 GDPR\) \(PDF, 249 KB\)](#)
- [Antrag gemäß Art. 17 DSGVO auf Löschung / Request for Erasure \(Article 17 GDPR\) \(PDF, 128 KB\) \(PDF, 436 KB\)](#)
- [Antrag gemäß Art. 18 DSGVO auf Einschränkung der Verarbeitung / Request for restriction of processing \(Article 18 GDPR\) \(PDF, 249 KB\)](#)
- [Antrag gemäß Art. 20 DSGVO auf Übertragung von Daten / Request for Data Portability \(Article 20 GDPR\) \(PDF, 248 KB\)](#)
- [Antrag gemäß Art. 21 DSGVO auf Widerspruch / Objection \(Article 21 GDPR\) \(PDF, 196 KB\)](#)



Verantwortliche

Verantwortliche

- Verantwortliche: ist die natürliche oder juristische Person, Behörde, Einrichtung oder andere Stelle, die allein oder gemeinsam mit anderen über die Zwecke und Mittel der Verarbeitung von personenbezogenen Daten **entscheidet**. (ehemals „datenschutzrechtlichen Auftraggebers“)
- **Ansprechpartner** für betroffene Betroffene und Behörden
- **Gesamtverantwortlich**, d.h. für den gesamten Datenverarbeitungsvorgang verantwortlich. Muss **nachweislich** Pflichten erfüllen

Verantwortliche: Pflichten

- Informationspflichten
- Risikoanalyse
- Implementierung der Datensicherheitsmaßnahmen
- Verzeichnis aller Datenverarbeitungstätigkeiten
- Ggf. Datenschutzbeauftragten bestellen
- Bei Datenschutzverletzung: Unverzügliche Meldung an Datenschutzbehörde (DSb)

Verantwortliche: Informationspflichten

Datenschutzerklärung (EN: Privacy Policy)

- **Namen und Kontaktdaten** des Verantwortlichen (bzw. der Vertreter)
- Ggf. Kontaktdaten des **Datenschutzbeauftragten**
- **Kategorien** der personenbezogenen Daten
- **Quellen und Empfänger** (inkl. Auftragsverarbeiter)
- **Verarbeitungszwecke** und **Rechtsgrundlagen** der Verarbeitung
- **Berechtigtes Interesse der Verarbeitung** (falls vorhanden)
- Möglichkeit des **Widerrufs**

Verantwortliche: Informationspflichten

Datenschutzerklärung (EN: Privacy Policy)

- **Dauer**
- **Betroffenenrechte** (Auskunft, Berichtigung, Löschung, Einschränkung, Datenübertragbarkeit und Widerspruch)
- **Beschwerderechts** bei einer Aufsichtsbehörde (DSb)
- **Gesetzliche und vertragliche Verpflichtungen**
- Bestehen **automatisierter Entscheidungsfindung** (z.B.: Profiling)

Verantwortliche: Informationspflichten

Kategorien: Name, Adresse, Geburtsdatum, E-Mail-Adresse, IP-Adresse, Kontonummer, Kfz-Kennzeichen, Interessen, Vorlieben, Logindaten, Accountdaten, Bankdaten, Positionsdaten, Versicherungsdaten, Nutzerdaten, Nutzungsdaten, Nutzungshistorie, Kommunikationsdaten, Bilddaten, Nachrichteninhalte, Vertragsdaten, Kontaktdaten, Metadaten, ...

Besondere Kategorien: rassische und ethnische Herkunft, politische Meinungen, religiöse oder weltanschauliche Überzeugungen oder die Gewerkschaftszugehörigkeit hervorgehen, sowie die Verarbeitung von genetischen Daten, biometrischen Daten zur eindeutigen Identifizierung einer natürlichen Person, Gesundheitsdaten oder Daten zum Sexualleben oder der sexuellen Orientierung einer natürlichen Person



TECHNISCHE
UNIVERSITÄT
WIEN

Verantwortliche: Informationspflichten

Daten direkt erhoben:

Für eine rasche Registrierung halten Sie bitte die Nummer einer Ihrer Polizzen zur Hand. Warum wir diese Information benötigen [finden Sie in unseren FAQs](#).

[Ich bin Firmenkunde](#)

Sie nutzen bereits unsere losleben-App? Verwenden Sie bitte Ihre bestehenden Anmeldedaten für das Kundenportal.

Vorname lt. Polizze

Alfred ✓

Nachname lt. Polizze

Soare ✓

Geburtsdatum TT.MM.JJJJ

01.01.1990 ✓

Polizzennummer K987654, K5-P389.162-2, 65-N002.178-7, 1012345678

K987654 ✓

Handynummer +436641234567

+436641234567 ✓

E-Mail-Adresse

alfred.soare@tuwien.ac.at ✓

Ich akzeptiere die [Nutzungsbedingungen](#) ✓

Ich akzeptiere die [Vereinbarung der elektronischen Kommunikation](#) ☐

Informationen zum [Datenschutz](#)

→ **Letzter Schritt**

Bitte füllen Sie alle Formularfelder korrekt aus, um fortzufahren.

Verantwortliche: Informationspflichten

Daten direkt erhoben:

Für eine rasche Registrierung halten Sie bitte die Nummer einer Ihrer Polizzen zur Hand. Warum wir diese Information benötigen [finden Sie in unseren FAQs](#).

Ich bin Firmenkunde

Sie nutzen bereits unsere losleben-App? Verwenden Sie bitte Ihre bestehenden Anmeldedaten für das Kundenportal.

Vorname lt. Polizze
Alfred ✓

Nachname lt. Polizze
Soare ✓

Geburtsdatum TT.MM.JJJJ
01.01.1990 ✓

Polizzennummer K987654, K5-P389.162-2, 65-N002.178-7, 1012345678
K987654 ✓

Handynummer +436641234567
+436641234567 ✓

E-Mail-Adresse
alfred.soare@tuwien.ac.at ✓

Ich akzeptiere die **Nutzungsbedingungen** ✓

Ich akzeptiere die **Vereinbarung der elektronischen Kommunikation** ✓

Informationen zum **Datenschutz**

→ **Letzter Schritt**

Bitte füllen Sie alle Formularfelder korrekt aus, um fortzufahren.

Verantwortliche: Informationspflichten

Daten aus anderen Quellen erhoben:

- Information **innerhalb eines Monats**
- Spätestens zum **Zeitpunkt der ersten Mitteilung**
- Spätestens zum **Zeitpunkt der ersten Offenlegung**

Verantwortliche: Informationspflichten

Ausnahmen

- Obsolet
- Unverhältnismäßiger Aufwand (z.B. bei Verarbeitung für im öffentlichen Interesse liegende Archivzwecke, für wissenschaftliche oder historische Forschungszwecke oder für statistische Zwecke)
- Erlangung oder Offenlegung durch Rechtsvorschriften
- Berufsgeheimnis oder einer satzungsmäßigen Geheimhaltungspflicht

Verantwortliche: Datensicherheitsmaßnahmen

- Pseudonymisierung
- CIA Triad
- Auftragsprinzip
- Selbstevaluierungsprozesse
- Zertifizierungsverfahren
- Privacy by Design, Privacy by Default

Verantwortliche: Verarbeitungsverzeichnis

- **Namen** und **Kontaktdaten** des Verantwortlichen (bzw. der Vertreter)
- Kontaktdaten des **Datenschutzbeauftragten** (falls vorhanden)
- **Verarbeitungszwecke** und **Rechtsgrundlagen** der Verarbeitung
- **Kategorien** der personenbezogenen Daten
- Kategorien von **Empfänger**
- Übermittlung an **Drittländer** (und Dokumentation der Garantien)
- **Löschfristen**
- **Datensicherheitsmaßnahmen**

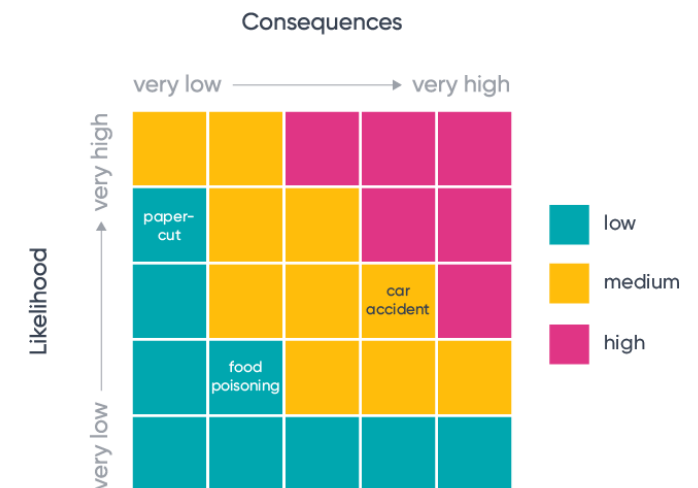
Verantwortliche: Verarbeitungsverzeichnis

Ausnahmen (mit AND-Verknüpft)

- Unternehmen < 250 Mitarbeiter
- Datenverarbeitung stellt kein Risiko für die Rechte und Freiheiten der betroffenen Personen
- Verarbeitung erfolgt nur gelegentlich
- Keine Verarbeitung von sensiblen Daten

Verantwortliche: Risikoanalyse

Prüfung ob eine Datenschutz-
Folgeabschätzung notwendig ist.



Verantwortliche: DSFA

DSFA ist erforderlich wenn die Verarbeitung voraussichtlich ein hohes Risiko für die Rechte und Freiheiten natürlicher Personen zur Folge hat.

- **Profiling** (systematische und umfassende Bewertung persönlicher Aspekte)
- Umfangreiche Verarbeitung **sensibler Daten**
- **Videoüberwachung** (umfangreichen Verarbeitung sensibler Daten)

Verantwortliche: DSFA

Beispiele, DSFA erforderlich:

- Eine Bank prüft ihre Kunden mithilfe einer Datenbank für die Kreditauskunft
- Ein Krankenhaus führt eine Datenbank mit Gesundheitsdaten
- Ein Busunternehmen richtet Kameras ein, um das Verhalten zu überwachen

Verantwortliche: DSFA

Kriterien zur Risikobewertung (Art-29-Gruppe Leitlinie)

- Profiling
- Automatisierte Entscheidungsfindung
- Systematische Überwachung
- Sensible Daten
- Umfangreiche Verarbeitung (Dauer, Anzahl, Ausmaß, ...)
- Verknüpfung von Datensätzen
- Schutzbedürftige Betroffene (Kinder, Arbeitnehmer, Kranke, ...)
- Innovative Technologien (Biometrische-2FA, IoT, AI, ...)
- Auswirkung auf Vertragsabschluss

Empfehlung: DSFA erforderlich, falls ≥ 2 Kriterien zutreffen OR „Rote Kategorie“

Verantwortliche: DSFA

Kriterien zur Risikobewertung

Beispiel 1

Ein Krankenhaus verarbeitet die genetischen und medizinischen Daten seiner Patienten
(Krankenhausinformationssystem, KIS)

Verantwortliche: DSFA

Kriterien zur Risikobewertung

Beispiel 1

Ein Krankenhaus verarbeitet die genetischen und medizinischen Daten seiner Patienten (Krankenhausinformationssystem, KIS)

- Sensible Daten
- Schutzbedürftige Betroffene
- Umfangreiche Verarbeitung

Verantwortliche: DSFA

Kriterien zur Risikobewertung

Beispiel 2

Ein Kamerasystem wird zur Überwachung des Fahrverhaltens auf Schnellstraßen eingesetzt. Zur Identifizierung einzelner Fahrzeuge und automatischen Erkennung von Nummernschildern plant der für die Verarbeitung Verantwortliche den Einsatz eines intelligenten Videoanalysesystems.

Verantwortliche: DSFA

Kriterien zur Risikobewertung

Beispiel 2

Ein Kamerasystem wird zur Überwachung des Fahrverhaltens auf Schnellstraßen eingesetzt. Zur Identifizierung einzelner Fahrzeuge und automatischen Erkennung von Nummernschildern plant der für die Verarbeitung Verantwortliche den Einsatz eines intelligenten Videoanalysesystems.

- Systematische Überwachung
- Innovative Technologien

Verantwortliche: DSFA

Kriterien zur Risikobewertung

Beispiel 3

Ein Online-Händler schaltet auf seiner Website Werbeanzeigen für Oldtimer-Ersatzteile, für die eine Profilerstellung auf der Grundlage von Produkten zum Einsatz kommt, die der Nutzer auf der Website des Online-Händlers angesehen oder gekauft hat.

Verantwortliche: DSFA

Kriterien zur Risikobewertung

Beispiel 3

Ein Online-Händler schaltet auf seiner Website Werbeanzeigen für Oldtimer-Ersatzteile, für die eine Profilerstellung auf der Grundlage von Produkten zum Einsatz kommt, die der Nutzer auf der Website des Online-Händlers angesehen oder gekauft hat.

- Profiling

Verantwortliche: DSFA

Kriterien zur Risikobewertung, Black-List gem. DSFA-V

- Bewertung oder Einstufung natürlicher Personen (Profiling)
- Automatisierte Entscheidungsfindung
- Systematische Überwachung öffentlicher Räume (Bild oder Tonaufnahmen)
- Innovative Technologien
- Unerwartete Verknüpfung von Datensätzen
- Verarbeitungsvorgänge im höchstpersönlichen Bereich

Verantwortliche: DSFA

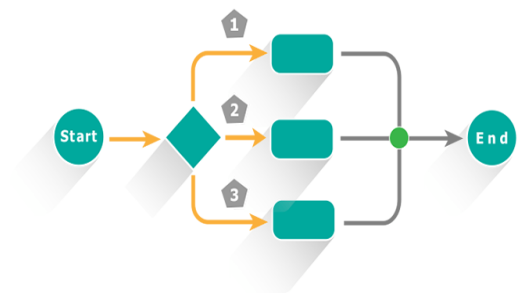
Kriterien zur Risikobewertung White-List gem. DSFA-AV

- Kundenverwaltungen, Rechnungswesen, Logistik und Buchführung
- Personalverwaltung
- Mitgliederverwaltung (z.B. bei Vereinen)
- Sach- und Inventarverwaltung
- Register, Evidenzen, Bücher
- Zugriffsverwaltung für EDV-Systeme
- Stationäre Bildverarbeitung und die damit verbundene Akustikverarbeitung zu Überwachungszwecken (Videoüberwachung)
- Bild- und Akustikdatenverarbeitung in Echtzeit
- Bild- und Akustikverarbeitungen zu Dokumentationszwecken
- ...

Datenschutzfolgeabschätzung (DSFA)

Beschreibung der geplanten Verarbeitungsvorgänge

- Art, Umfang, Umstände der Datenverarbeitung
- Personenbezogenen Daten, Empfänger und Speicherfrist
- funktionale Beschreibung der Verarbeitungsvorgänge
- Hardware, Software, Netzwerke, Benutzerkreise, ...
- Dokumentation, Richtlinien



Datenschutzfolgeabschätzung (DSFA)

Verarbeitungszweck

- Rechtmäßigkeitsgrundlage des berechtigten Interesses
- Gesetz, Richtlinie, Vertrag





Datenschutzfolgeabschätzung (DSFA)

Notwendigkeit und Verhältnismäßigkeit

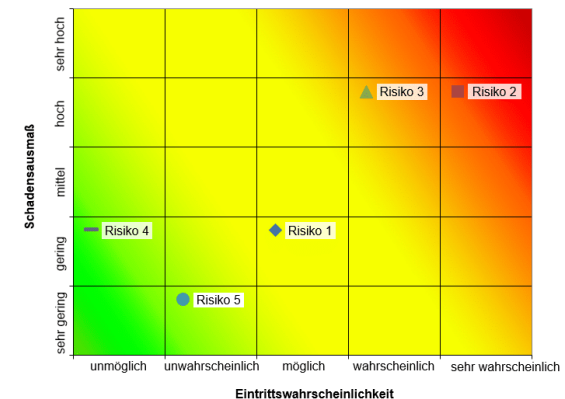
Datenverarbeitung ist für den Verarbeitungszweck unumgänglich. Prüfkriterien:

- Zweck ist legitim
- Datenverarbeitung ist für den Zweck erheblich, angemessen sowie auf das notwendige Maß beschränkt
- Maßnahmen für die Erfüllung der Betroffenenrechte ergriffen (Auskunft, ...)
- Zuverlässiger Auftragsverarbeiter, bei Internationalen Datenverkehr „Garantien“
- Adäquater Vertrag mit Auftragsverarbeiter

Datenschutzfolgeabschätzung (DSFA)

Risikobewertung hinsichtlich Betroffenenrechte und Grundprinzipien

- Ursache, Art und Schwere der Risiken (unerwünschter Zugriff, ...)
- Risikoquellen (Interner Angreifer, ...)
- Auswirkungen auf die Betroffenen
- Eintrittswahrscheinlichkeit
- Maßnahmen



Datenschutzfolgeabschätzung (DSFA)

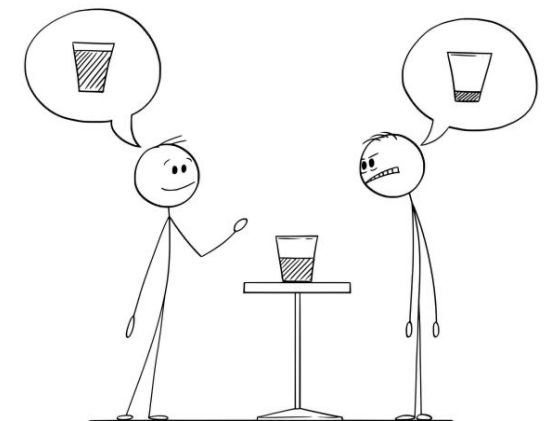
Abhilfemaßnahmen (Garantien, Sicherheitsvorkehrungen und Verfahren)

- Pseudonymisierungs- oder Anonymisierungsmaßnahmen
- Organisatorische oder personelle Maßnahmen (Zutritts- oder Zugangsbeschränkungen,
- Zertifizierungen, Prozesse, Richtlinien
- Technische Maßnahmen (Protokollierung, Verschlüsselung, Löschfristen, ...)
- IT-Sicherheit (Endpoint-Protection, Passwortregeln, Schulungen, Firewalls, ...)
- Datensicherung (Backups, Notfallprozesse, ...)
- Bauliche Maßnahmen (Bereiche, Kontrollen, Sperrkreise)

Datenschutzfolgeabschätzung (DSFA)

Standpunkt der Betroffenen

- Alternative: Standpunkt der Vertreter
- Alternative: Begründung weshalb Standpunkt nicht eingeholt wurde
(Unverhältnismäßigkeit, Impraktikabilität, Geheimhaltungspflichten, ...)
- Eine Begründung ist erforderlich, falls die Entscheidung des Verantwortlichen vom Standpunkt der Betroffenen abweicht.



Datenschutzfolgeabschätzung (DSFA)

Datenschutzbeauftragten

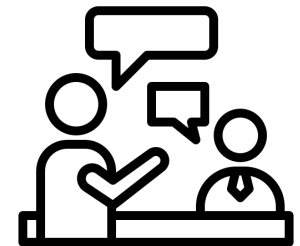
- Empfehlungen vom Datenschutzbeauftragten
- Getroffene Entscheidung.



Datenschutzfolgeabschätzung (DSFA)

Konsultation der Datenschutzbehörde, falls Ergebnis DSFA = hohes Risiko und Verantwortlicher kann keine Maßnahmen zur Eindämmung treffen.

- Verantwortliche, Datenschutzbeauftragte und Auftragsverarbeiter.
- Zwecke und die Mittel der beabsichtigten Verarbeitung
- Maßnahmen zum Schutz der Betroffenenrechte und Garantien
- Datenschutzfolgeabschätzung



Data Breach Meldung

- Meldung an die DSb bei einem Risiko
- Meldung an die betroffenen Personen bei einem hohen Risiko
- Unverzüglich, spätestens nach 72h ab Bekanntheit
- Inhalt:
 - Art der Verletzung der Rechte und Freiheiten
 - Wahrscheinlichen Folgen und Konsequenzen
 - Getroffene Maßnahmen zur Behebung des Databreaches
 - Kontaktdaten



Datenschutzbeauftragte

Aufgaben

- Beratung des Unternehmens und Mitarbeiter hinsichtlich DSGVO-Pflichten
- Überwachung und Überprüfung der Einhaltung der Datenschutzvorschriften
- Sensibilisierung und Schulung der Mitarbeiter
- Beratung DSFA, Verzeichnis, Applikationsbeschreibung, ...
- i.d.R. Bearbeitung von Begehren, Dialog mit Betroffenen



Datenschutzbeauftragte

Qualifikationen

- Fachliches Wissen insb. auf dem Gebiet Datenschutzrechts
- Fähigkeit, um die Aufgaben zu erfüllen.
- Möglicher Zertifizierungen
 - TÜV, WIFI, ETC (ca. 3.000 EUR, 40h + Prüfung, 3 Jahre gültig)



Datenschutzbeauftragte

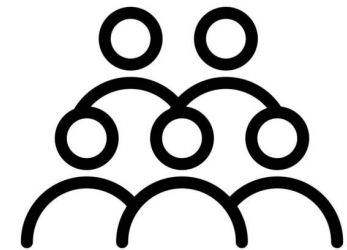
Verpflichtende Bestellung

- In der Kerntätigkeit: umfangreiche regelmäßige und systematische Überwachung von betroffenen Personen (z.B. Banken, Versicherungen, Kreditauskunfteien, Detektive, ...)
- Verarbeitung von sensiblen Daten



Gemeinsame Verantwortliche

- Ehemals „Informationsverbundsystem“ (DSG2000)
- Zwei oder mehrere Verantwortliche
- Vereinbarung über die Aufteilung der Verpflichtungen
 - Folgen auf Regressansprüche
- Betroffene können gegenüber jedem Verantwortlichen Rechte geltend machen.



Vertreter

Vertreter

Pflicht Vertreter zu bestellen, falls:

- Keine Niederlassung in der EU
- Waren und Dienstleistungen werden in der EU angeboten
- Verhalten der Personen in der EU wird beobachtet
- Ausnahmen u.a. für Behörden.

Pflichten:

- Vertretung hinsichtlich DSGVO Pflichten
- Anlaufstelle für Behörden und Betroffenen



TECHNISCHE
UNIVERSITÄT
WIEN

Auftragsverarbeiter

Auftragsverarbeiter

Beispiel:

- IT-Dienstleister

Gegenbeispiel:

- Steuerberater

Auftragsverarbeiter: Pflichten

- Implementierung der Datensicherheitsmaßnahmen
- Verzeichnis aller Datenverarbeitungstätigkeiten
- Ggf. Datenschutzbeauftragten bestellen
- Risikoanalyse
- Unterstützung des Verantwortlichen in der Erfüllung der DSGVO Pflichten
- Zusammenarbeit mit Aufsichtsbehörden (DSb)
- Warnpflicht

Verantwortlichen – Auftragsverarbeiter

- **Standardklauseln** ("Standardvertragsklauseln für Verantwortliche und Auftragsverarbeiter in der EU / im EWR, 2021")
 - Bindung an Verantwortlichen
 - Dauer der Verarbeitung
 - Art und Zweck der Verarbeitung
 - Kategorien
 - Pflichten und Rechte
 - Unterauftragsverarbeiter: Gegenstand, Art, Dauer

Vertrag: Verantwortlichen – Auftragsverarbeiter

Inhalte:

- Personenbezogenen Daten nur auf dokumentierte Weisung des Verantwortlichen verarbeitet werden (oder gesetzliche Verpflichtung)
- Gewährleistung über Vertraulichkeit, Sicherheitsmaßnahmen
- Genehmigung Unterauftragsverarbeiter
- Unterstützung bei DSGVO Verpflichtungen (Anträge, Meldungen, ...)
- Löschung personenbezogenen Daten nach Vertragserfüllung

© COPYRIGHT- ODER QUELLENHINWEIS,

Internationaler Datenverkehr: Geschichte US-EU

- Safe Harbour Abkommen 2000 – 2016
- EU-US Privacy Shield Abkommen 2016 - 2020
- EU-US Data Privacy Framework seit 2023
 - Executive Order on Enhancing Safeguards for United States Signals Intelligence Activities, Biden 2022
 - US-Nachrichtendienste haben eingeschränkten Datenzugriff
 - Data Protection Review Court (DRPC) eingerichtet



© COPYRIGHT- ODER QUELLENHINWEIS,

Internationaler Datenverkehr

Datenverkehr nicht genehmigungspflichtig

- EU und EWR-Länder
- Drittländer mit aufrechten Angemessenheitsbeschluss (alle 4 Jahre erneuert)
Andorra, Argentinien, Färöer Inseln, Guernsey, Insel Man, Israel, Japan, Jersey, Kanada, Neuseeland, Schweiz, Südkorea, Uruguay, UK , USA* (*ausschließlich zertifizierte Unternehmen, siehe Data Privacy Framework List)
- <https://www.dataprivacyframework.gov/list>

© COPYRIGHT- ODER QUELLENHINWEIS,

Internationaler Datenverkehr: SCC

- Standardschutzklauseln müssen von der EC oder einer Aufsichtsbehörde abgenommen werden.
- Rechtsverbindlichen und durchsetzbaren Verpflichtungen zur Anwendung der geeigneten Garantien
- Datenexporteure und Datenimporteure müssen prüfen, ob das Recht im Drittland die Wirksamkeit der oben genannten Garantien beeinträchtigt.

© COPYRIGHT- ODER QUELLENHINWEIS,

Strafen

Strafen



Gravierende Verstöße

Bis zu 20 Mio. EUR Strafe

Bis zu 4% des gesamten weltweit erzielten Jahresumsatzes für Unternehmen

Weniger gewichtige Verstöße

Bis zu 10 Mio. EUR Strafe

Bis zu 2% des gesamten weltweit erzielten Jahresumsatzes für Unternehmen

Behörden

Datenschutzbehörde (DSb)



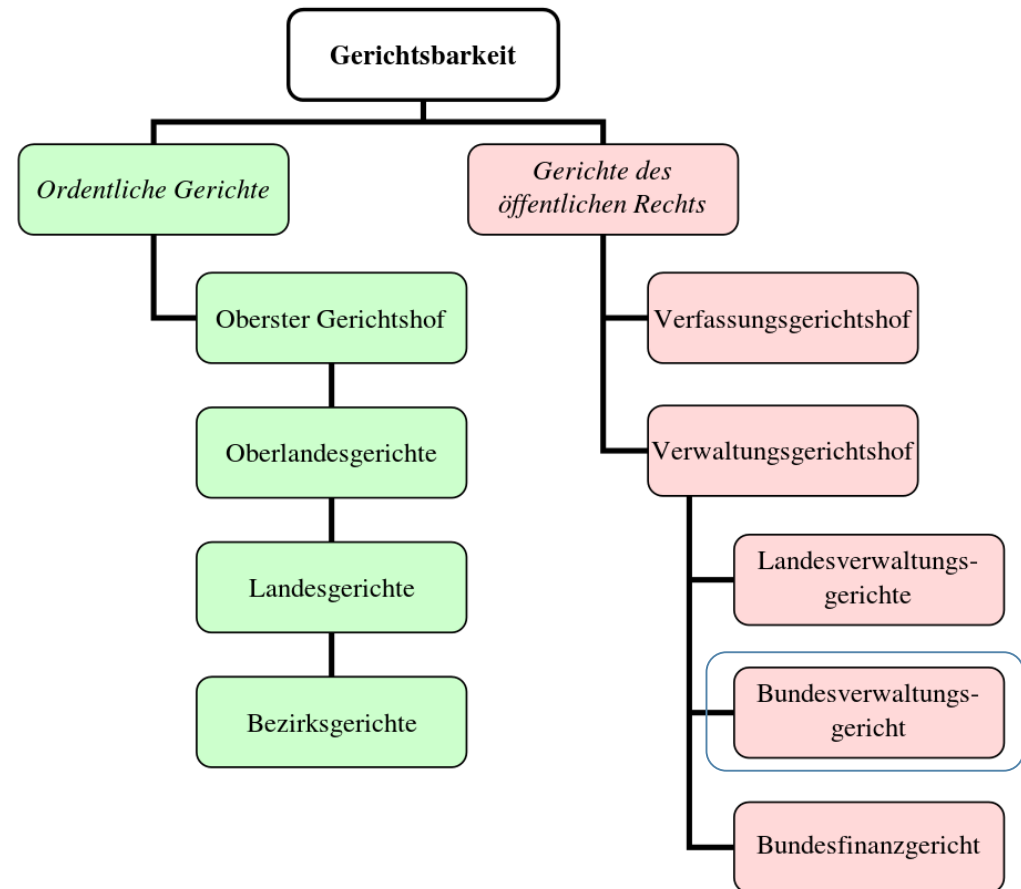
Republik Österreich
Datenschutz
behörde

- Unabhängige Justizbehörde, Aufsichtsbehörde für Datenschutz
- Leiter:in von BReg. nominiert und vom BPräs. auf 5 Jahre bestellt.

Aufgaben:

- Führung von datenschutzrechtlichen Beschwerdeverfahren
- Amtswegige Prüfverfahren
- Verwaltungsstrafverfahren
- Zusammenarbeit mit anderen Datenschutzbehörden

Exkurs: Gerichtsbarkeit

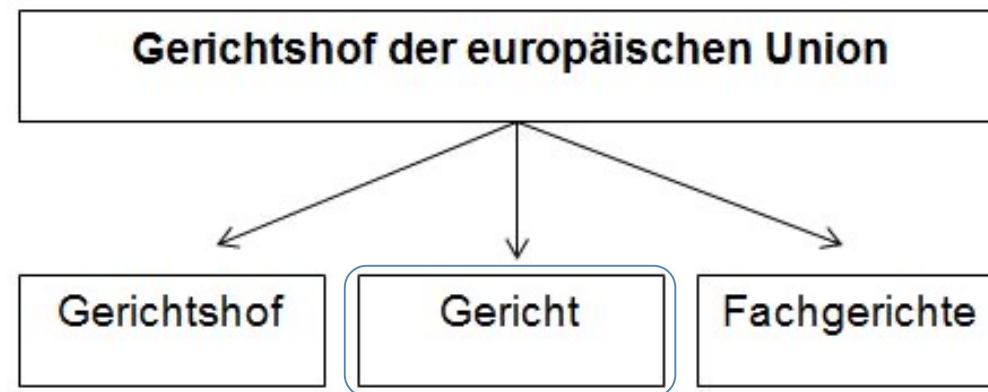


Datenschutzausschuss (EDSA)



- Ehemals Artikel-29-Datenschutzgruppe
- Entscheiden grenzüberschreitende Fälle
- Beratung der EU-Kommission
- Bereitstellung von Leitlinien, Empfehlungen und bewährten Verfahren
- Akkreditierung und Prüfung von Zertifizierungsstellen
- Mitglieder aus allen EWR-Ländern.

Exkurs: EUG



Praxistipps

Sicherheitsmaßnahmen

- Präventiv
- Detektiv
- Reaktiv
- Abschreckend
- Technisch
- Organisatorisch
- Physisch

Sicherheitsmaßnahmen

	Präventiv	Detektiv	Reaktiv	Abschreckend
Technisch	Firewall	Endpoint Protection	Restoreplan	Protokollierung
Organisatorisch	Awareness Schulung	IT-Analysten	Maßnahmenplan	Stichproben
Physisch	Tresor	Lichtschraken	Alarm	Kameras

Werbung

Opt-In erforderlich:

- Telefonwerbung (§174 TKG)
- E-Mail-Werbung an nicht Kunden
- Verwendung sensibler Daten
- Profiling
- ...

Opt-Out möglich:

- Postalische Werbung (§ 151 Abs 9 GewO)
- Werbung an Kunden (§174 TKG)
- ...



Cookies

[< Zurück](#)

Datenschutzeinstellungen

Wir setzen verschiedene Arten von Cookies ein, um Ihnen ein optimales Webseiten Erlebnis zu bieten. Im Folgenden finden Sie weitere Informationen zu unseren Cookie-Kategorien und den Einstellungsmöglichkeiten:

<https://policies.google.com/privacy>

Funktionsnotwendige Cookies

immer aktiv 

Diese Cookies sind zur Funktion unserer Website erforderlich und können in unseren Systemen nicht deaktiviert werden.

Leistungsbezogene Cookies

Diese Technologien ermöglichen es uns, die Nutzung analysieren, Fehler zu finden, um die Leistung zu messen und zu verbessern.

Weitere Dienste-Cookies

Ermöglicht die Einbindung externer Informationen und Services von Drittanbietern, beispielsweise das Einbetten von Karten, Videos oder Sicherheitsfunktionen.

Marketing Cookies

Diese Technologien werden von Werbepartnern verwendet, um Anzeigen zu schalten, die für Ihre Interessen relevant sind und Marketingaktivitäten zu optimieren.

[Cookie Einstellungen](#)

Alle Akzeptieren

Einstellungen speichern

Cookies

- Einwilligung erforderlich (§165 ff TKG 2021)
 - Ausnahme: funktionale Cookies
- Informationen in Datenschutzerklärung
- Device Fingerprinting umstritten
(Artikel-29-Datenschutzgruppe empfiehlt Einwilligung)

